

Индивидуальный проект

Четвертый этап

Устинова В. В.

01 мая 2026

Российский университет дружбы народов, Москва, России

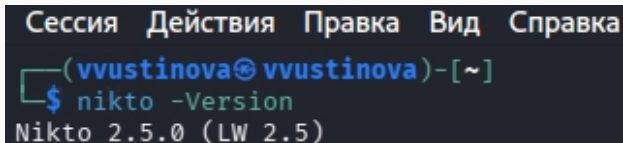
Информация

- Устинова Виктория Вадимовна
- студент НПИбд-01-24
- Российский университет дружбы народов

Научиться основным способам использования nikto

1. nikto — базовый сканер безопасности веб-сервера. Он сканирует и обнаруживает уязвимости в веб-приложениях, обычно вызванные неправильной конфигурацией на самом сервере, файлами, установленными по умолчанию, и небезопасными файлами, а также устаревшими серверными приложениями.

Проверяем скачан ли nikto



```
Сессия Действия Правка Вид Справка
(vvustinova@vvustinova)-[~]
$ nikto -Version
Nikto 2.5.0 (LW 2.5)
```

Рис. 1: Так как мы видим его версию, соответственно он скачан

Выполнение лабораторной работы

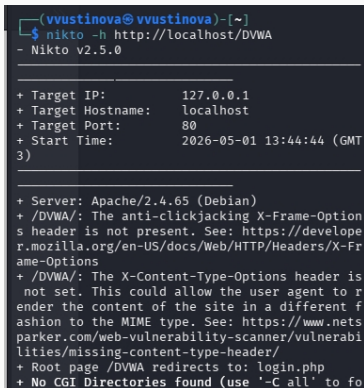
Проверяем какие утилиты у него есть

```
(vvustinova@vvustinova)-[~]
$ nikto -Hepl
Unknown option: Hepl

Options:
  -ask+          Whether to ask abo
ut submitting updates
  yes          Ask abou
t each (default)
  no           Don't as
k, don't send
  auto        Don't as
k, just send
  -check6      Check if IPv6 is w
orking (connects to ipv6.google.com or value
set in nikto.conf)
  -Cgidirs+    Scan these CGI dir
s: "none", "all", or values like "/cgi/ /cgi-
a/"
  -config+    Use this config fi
le
  -Display+   Turn on/off displa
```

Выполнение лабораторной работы

Вводим основную команду и смотрим вывод



```
(vvustinova@vvustinova)-[~]
$ nikto -h http://localhost/DVWA
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 80
+ Start Time: 2026-05-01 13:44:44 (GMT 3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsec.org.uk/articles/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force)
```

Рис. 3: Следующий слайд

1. The anti-clickjacking X-Frame-Options header is not present. сайт не запрещает другим сайтам вставлять себя во фрейм. Этим могут воспользоваться злоумышленники: они поместят ваш сайт внутрь своего сайта, а поверх наложат невидимые кнопки. Когда вы будете кликать по картинкам, на самом деле будете нажимать на скрытую кнопку «Перевести деньги». Это называется clickjacking.
2. The X-Content-Type-Options header is not set. Браузер иногда сам угадывает тип файла (например, файл .txt пытается выполнить как JavaScript). Хакеры могут этим воспользоваться, загрузив на сайт картинку, внутри которой написан вредоносный скрипт. Браузер может по ошибке выполнить его.

3. Root page /DVWA redirects to: login.php Это не уязвимость, а особенность. Просто при переходе на `http://localhost/DVWA` сервер отправляет вас на страницу входа `login.php`. Это нормально для приложений с авторизацией.
4. /DVWA/config/: Directory indexing found. Если вы откроете в браузере `http://localhost/DVWA/config/`, вы увидите список всех файлов в этой папке. Поскольку в /config/ обычно лежат важные настройки (файлы с паролями к базе данных, ключи шифрования), любой, кто знает путь, сможет их скачать.

Мы научились основным способам использования nikto